
MASTER UNIVERSITARIO DI I LIVELLO IN CYBERSICUREZZA

Notarizzazione forense immutabile di audit log tramite Merkle Tree su L2

Infrastruttura distribuita per la certificazione crittografica e catena di custodia non ripudiabile

CANDIDATO

Andrea Mellano

ARCHITETTURA DI RIFERIMENTO

Arbitrum Sepolia L2 • Merkle Engine



Il Problema Principale: Assenza di Trust sui Log Locali

ANALISI DELLE VULNERABILITÀ

Criticità fondamentale dei sistemi tradizionali di monitoraggio e audit log

01

Rischio Manomissione

Totale assenza di meccanismi attivi di protezione contro manomissioni a posteriori.

Un utente malevolo o un malware con privilegi elevati può facilmente alterare o cancellare le proprie tracce.

 Vulnerabilità Log • Tamper Risk

02

Zero Prova Crittografica

Mancanza assoluta di garanzie matematiche riguardanti l'integrità e la non ripudiabilità.

Impossibilità di dimostrare il valore probatorio dei dati in sede forense o durante audit di sicurezza.

 Assenza di Hash • No Timestamp



L'Obiettivo del Progetto

Superare queste criticità mediante un'infrastruttura di notarizzazione forense immutabile e non ripudiabile, svincolata dal controllo locale dell'host.

Notarizzazione forense immutabile di audit log tramite Merkle Tree su L2

Infrastruttura distribuita per la certificazione crittografica e catena di custodia non ripudiabile

MASTER UNIVERSITARIO DI I LIVELLO IN CYBERSICUREZZA

01

Integrità Crittografica

Aggregazione logica e riduzione ad impronta binaria univoca tramite alberi di Merkle e Keccak-256.

Garantisce la rilevazione immediata di qualsiasi alterazione o manomissione a posteriori sui log.

⚙️ Merkle Tree • Keccak-256

02

Ancoraggio Layer 2

Notarizzazione continua ad altissima efficienza economica e timestamp imparziale su Arbitrum Rollup.

Assicura certezza temporale non alterabile ed ereditarietà della sicurezza da Ethereum Mainnet.

⚙️ Arbitrum Rollup • Smart Contract

03

Validazione Forense

Garante della catena di custodia con audit indipendenti e verifiche matematiche client-side Zero-Knowledge.

Permette l'ispezione immediata delle prove di inclusione senza divulgazione di dati riservati.

⚙️ Zero-Knowledge • Client Verification

Perché Blockchain e Layer 2

SCELTE ARCHITETTURALI



Requisiti Forensi • Perché la Blockchain

1

Immutabilità Crittografica

Registro distribuito protetto da consenso matematico e crittografia asimmetrica irreversibile.

2

Block Timestamp Imparziale

Marca temporale certificata dal Sequencer L2, del tutto indipendente dal clock dell'host.

3

Non Ripudio della Fonte

Ogni blocco notarizzato è firmato crittograficamente dall'account univoco dell'endpoint (EOA).

4

Tutela Totale della Privacy

Zero leak di dati sensibili: solo hash e radici a 32 byte on-chain, pienamente conforme a GDPR e NIS2.



Perché Rollup L2 (Arbitrum) vs L1

1

Costi di Transazione Minimi

Oltre 100 volte più economico di Ethereum L1 (< \$0.001 per ancoraggio batch continuo).

2

Latenza Sub-Secondo

Conferme di inclusione istantanee, indispensabili per pipeline di incident response in tempo reale.

3

Sicurezza Ereditata da L1

I dati di rollup sono pubblicati su Ethereum Mainnet, ereditandone l'inviolabilità del consenso.

4

Piena Compatibilità EVM

Utilizzo dello standard Solidity e interoperabilità nativa con toolchain e librerie Web3 enterprise.



Sinergia perfetta: la Blockchain conferisce valore probatorio legale, il Layer 2 garantisce sostenibilità economica.

Architettura di Sistema End-to-End

COMPONENTI CORE

01

FASE LOCAL AGENT

Endpoint Agent

Demone autonomo in esecuzione sull'host Linux.

- Intercetta a basso livello i log binari (/var/log/btmp).
- Normalizza le entry ed esegue il hashing.
- Costruisce localmente l'albero di Merkle.

⚙️ Linux VPS • Python Daemon

ROOT
→

02

ANCHORING ON-CHAIN

Smart Contract su L2

Contratto Solidity deployato su Arbitrum Sepolia.

- Gestisce la whitelist autorizzativa degli host.
- Garantisce timestamp notarizzato ed immutabile.
- Archivia esclusivamente la Root a 32 byte.

⚙️ LogNotary • Arbitrum Rollup

VERIFY
→

03

VERIFICA FORENSE

Forensic Verifier

Web3 Dashboard per verificatori e periti.

- Permette l'ispezione dello stato dei nodi.
- Verifica client-side drag & drop dei file log.
- Ricalcola e convalida la Merkle Proof.

⚙️ Firebase Web3 • Ethers.js



Disaccoppiamento totale: l'agente trasmette solo l'impronta crittografica; i dati sensibili restano nel perimetro aziendale.

Compressione Crittografica $O(1)$

Ogni singolo record di audit viene trasformato in una foglia crittografica applicando la funzione hash Keccak-256 alla stringa canonica:

Leaf = keccak256(RawLogString)

Le foglie adiacenti vengono accoppiate e hashate ricorsivamente a livelli successivi fino a convergere in una singola radice a 32 byte (Merkle Root).

Verifica Logaritmica $O(\log n)$

- Zero-Knowledge Parziale: Non occorre rileggere l'intero database di audit né esporre gli altri log contenuti nel lotto.
- Efficienza Scalabile: Per un albero contenente 1.024 log, bastano appena 10 hash intermedi (nodi fratelli) per convalidare l'integrità.
- Sensibilità all'Alterazione: La modifica anche di un solo bit produce una Root divergente da quella registrata su Arbitrum.



Complessità ridotta: per convalidare 1 milione di log servono solo 20 hash di prova Merkle.

Resilienza: Batching & Heartbeat

AFFIDABILITÀ OPERATIVA



HIGH-FREQUENCY & BATCH

Trigger per Soglia di Volume

- Condizioni operative: Attivo in traffico nominale o durante attacchi ad alta frequenza (es. brute-force SSH).
- Accumulo buffer: L'agente accumula gli eventi fino al raggiungimento del limite (es. BATCH_SIZE = 50).
- Esecuzione immediata: Genera l'albero di Merkle e invia la transazione di notarizzazione al Sequencer L2.
- Efficienza dei costi: Ammortizza le commissioni sigillando decine o centinaia di log con una singola transazione.



LOW-TRAFFIC & TIMEOUT

Trigger per Timeout Heartbeat

- Condizioni operative: Entra in azione in situazioni di basso traffico o silenzio operativo prolungato.
- Forzatura del flush: Allo scadere della finestra (es. 60s o 120s), l'agente forza l'invio dei log presenti.
- Protezione continua: Evita che singoli eventi isolati rimangano non protetti in memoria per ore.
- Certezza temporale: Fissa un limite massimo all'incertezza temporale tra evento e notarizzazione L2.



Doppia garanzia: efficienza sui grandi volumi e protezione immediata anche a traffico zero.

LogNotary: Architettura On-Chain L2

SICUREZZA & ARCHITETTURA ON-CHAIN

RUOLO: SOC ADMIN

- **Chiave EOA Amministratore**
Controllo Accessi RBAC (Ownable)
`registerHost()` / `offboardHost()`

RUOLO: HOST LINUX AGENT

- **EOA Endpoint Certificato**
Scrittura limitata (onlyActiveHost)
`recordBatchRoot(id, root, count)`

RUOLO: AUDITOR / DAPP

- **Verifica Client-Side Drag & Drop**
Zero-Knowledge Parziale & Keep-Alive
`verifyLeafProof()` [Gasless View]

SMART CONTRACT: LogNotary.sol (Arbitrum Sepolia L2)

1. Registro & Whitelist Endpoint

`mapping(address => Host) hosts`

- `hostname: "srv-prod-ssh-01"`
- `ipAddress: "93.39.136.131"`
- `isActive & registeredAt timestamp`

2. Ancoraggio & Certificazione

`batchRoots[UUID] => MerkleRoot`
`mapping(string => BatchMetadata)`

- `recorder: msg.sender (EOA)`
- `timestamp (L2) & logCount record`

3. Verifica Matematica & Audit

`verifyLeafProof(id, leaf, proof) view`

- Chiamata View a Costo Zero Gas
- Validazione EVM e Client-Side
- `MerkleProof.verify(proof, root, leaf)`

Storage O(1) & Privacy GDPR

Solo 32 byte di Merkle Root on-chain. Nessun log grezzo archiviato (Gas minimo & privacy totale).

Timestamp Imparziale L2

Marca temporale sigillata dal Sequencer Arbitrum L2, immune a manipolazioni o timestomping dell'host.

Non-Ripudio della Fonte

Identità della sorgente garantita dalla firma crittografica della chiave EOA dell'endpoint autorizzato.

 **Governance, Ancoraggio Immutabile e Verifica Forense su Smart Contract Arbitrum Sepolia L2**

Smart Contract L2: Architettura On-Chain e Governance

LogNotary.sol • Controllo accessi RBAC, immutabilità probatoria e storage $O(1)$ su Arbitrum

ARCHITETTURA & GOVERNANCE ON-CHAIN

RUOLO & PERMESSI

1. Modello di Minaccia & RBAC

Chi può scrivere?

- **Separazione Ruoli (Dual-Actor):** L'admin SOC (onlyOwner) governa il ciclo di vita dei nodi con registerHost / offboardHost, ma non può iniettare radici di log al posto dei server.
- **Whitelist & Modifiers:** L'agente locale invoca recordBatchRoot solo se espressamente autorizzato (onlyActiveHost).
- **Contromisura di Incidente:** Se un endpoint viene violato, l'isolamento è immediato (isActive = false), revocando all'istante i permessi di scrittura on-chain.

OTTIMIZZAZIONE EVM

2. Storage Layout & Risparmio Gas

Cosa viene salvato?

- **Compressione Radicale $O(1)$:** Memorizzati unicamente batchId, radice bytes32 (32 byte) e logCount. Zero payload di testo raw allocato nello storage EVM.
- **Prevenzione Sovrascritture:** Check batchRoots[_batchId] != bytes32(0) per impedire attacchi di tipo *history overwriting*.
- **Standard EVM Moderni:** Custom Errors (HostNotActive, BatchAlreadyExists) e calldata per minimizzare il consumo di gas per transazione.

VALORE PROBATORIO

3. Valore Legale & Custodia

Come si prova l'integrità?

- **Block Timestamp Imparziale:** Sigillato da block.timestamp del Sequencer L2, immune al *timestamping* o manipolazioni dell'host Linux.
- **Firma Asimmetrica EOA:** Il record traccia recorder = msg.sender, garantendo il non-ripudio crittografico della sorgente.
- **Verifica Gasless:** Audit on-chain eseguibile via verifyLeafProof a costo di gas zero tramite chiamate view (OpenZeppelin MerkleProof).

Principio Architetture: Registro Notarile Crittografico

"Lo smart contract non funge da database, ma da **registro notarile crittografico**: delega la conservazione dei dati all'infrastruttura locale aziendale e garantisce sulla blockchain la certezza temporale, l'autenticità della sorgente e l'inviolabilità matematica."

Scenario Nominale

L'archivio JSON estratto dalla VPS corrisponde matematicamente alla radice registrata on-chain.

INTEGRO (Merkle Proof Validata)

Tentativo di Manomissione

Anche la modifica di un singolo carattere (IP sorgente o utente) altera completamente l'hash della foglia.

MANOMESSO (Root Mismatch)

Monitoraggio Heartbeat

La dashboard calcola la differenza temporale tra il blocco L2 e l'ora corrente per rilevare nodi silenti.

KEEP-ALIVE CERTIFICATO



Verifica Client-Side: l'auditor esegue il calcolo in locale senza inviare dati sensibili a server terzi.

Valore per l'organizzazione e Conclusioni

IMPATTO OPERATIVO



STRATEGIA & COMPLIANCE

Vantaggi Strategici per il SOC

- Catena di Custodia Non Ripudiabile: Garanzia matematica dell'integrità dei log producibile in sede legale e contenziosi.
- Rilevamento Anti-Forensics: Identificazione istantanea se un insider tenta di azzerare o ritoccare il database locale.
- Conformità Normativa Elevata: Piena aderenza agli standard ISO/IEC 27001, direttiva NIS2 e requisiti GDPR di integrità del dato.



ROADMAP TECNOLOGICA

Evoluzioni Future

- Integrazione SIEM / SOAR: Connettori e plugin per il forwarding automatico verso Splunk, Sentinel o Wazuh.
- Rotazione e Cold Storage: Offloading periodico degli archivi firmati su storage immutabili WORM / AWS S3 Glacier.

 **Dalla reattività alla garanzia probatoria: trasformazione dell'audit log in prova crittografica certa.**

Grazie per l'attenzione

CANDIDATO
Andrea Mellano

CORSO
Master II Livello Cybersicurezza

CORSO
Blockchain & Payments